

Data Retention & Deletion Policy

Parent: INFOSEC_POLICY.md, PRIVACY_POLICY.md **Owner:** Matt Fellows — matt@tangiblevalue.com
Effective date: 2026-05-06 **Review cadence:** annually, or any time the data model or use case materially changes.

1. Principle

The application retains user data only for the duration the user wishes to use the application's personal financial-tracking features. Plaid-derived data is removed automatically when the underlying institution is disconnected. Account-level data is removed on request.

There are no automatic retention windows beyond the trigger conditions in §3 — historical transaction data is intentionally kept for as long as the user wants the long-term-trend view, which is the application's primary purpose.

2. What's stored

See PRIVACY_POLICY.md §3 for the full inventory. Summarized:

- **Account & credential data:** users document (email, password hash), passkeys (per-credential metadata).
- **Plaid integration data:** plaid_items (with the encrypted access token), plaid_accounts, plaid_transactions, plaid_holdings, plaid_liabilities.
- **Application-generated data:** expenses, trades, investment_ideas, bets, budgets, balance_snapshots, settings.
- **Audit data:** sync_logs, consents.

3. Retention triggers

Event	Effect
Account is created	Account-level data and any associated user-generated data is retained until the user deletes the account.
User initiates Plaid Link for a new institution	A row is added to consents (kept indefinitely as audit), and the new institution + access token row is added to plaid_items.
User disconnects an institution (clicks "Disconnect" in the UI; DELETE /api/plaid/accounts/:itemId)	plaidService.removeItem calls client.itemRemove (revokes the access token at Plaid). The plaid_items row + every row in plaid_accounts, plaid_transactions, plaid_holdings, plaid_liabilities for that item is deleted from Firestore. The consents row remains as audit history.
User requests full account deletion (see §4)	Operator runs the deletion script. Access tokens revoked at Plaid for every institution; every user-scoped Firestore row removed; users document removed. The consents row is removed as part of the wipe.
Account inactivity	No automatic deletion. Inactive accounts persist until the user requests deletion.
No passkey registered + 365 days inactive	No automatic deletion. Reviewed at the annual policy review (this doc).

4. Account deletion procedure

Deletion is **request-based with a 7-day SLA**.

How a user requests deletion

By emailing matt@tangiblevalue.com with the subject line Delete my account from the email address registered on the account. The Operator may reasonably ask for re-authentication if the request is sent from a different address.

How the Operator fulfills the request

1. **Within 24h of receipt:** acknowledge the request by reply, restate what will be deleted, and ask for confirmation.
2. **After confirmation, within 7 days of original request:** run the deletion script.
3. **Within 24h of completion:** confirm by reply that deletion is complete and the account is unrecoverable.

The deletion script is `backend/scripts/deleteUser.js`. It is invoked locally by the Operator with:

```
cd backend && node scripts/deleteUser.js <email>
```

Behavior:

1. Looks up the user by email.
2. Prints a pre-flight count of every Firestore row that will be deleted.
3. Prompts the Operator to type DELETE to proceed (or anything else aborts).
4. For each row in `plaid_items` for that user, calls `plaidService.removeItem` to **revoke the access token at Plaid** (so even the Operator cannot resurrect data later).
5. Deletes all rows in the following collections where `user_id == <user_id>`:
 - `plaid_items`, `plaid_accounts`, `plaid_transactions`, `plaid_holdings`, `plaid_liabilities`
 - `sync_logs`, `expenses`, `trades`, `investment_ideas`, `bets`, `balance_snapshots`, `budgets`
 - `passkeys`, `consents`
6. Deletes `settings/<user_id>` (keyed by user ID, not `user_id` field).
7. Deletes `users/<user_id>`.

If a Plaid item-removal call fails (e.g., Plaid is briefly unavailable, or the item was already revoked), the script logs the failure and continues with the local Firestore wipe — local data is removed regardless. The Operator follows up with Plaid manually if any items did not revoke cleanly.

The list of user-scoped collections is also enumerated in the script itself (`USER_SCOPED_COLLECTIONS`). When a new user-scoped collection is added to the application, this list and §2 above must be updated **in the same change**.

5. Backups

This application does not maintain its own backups beyond what Firebase provides. Firestore retains its own platform-level backups per Google's Firestore service terms. Account deletion via the procedure in §4 does not retroactively purge Google-side backups; those age out per Google's schedule. Plaid `access_tokens` are never recoverable post-revocation regardless of any backup state.

If the Operator ever enables explicit Firestore exports / backups for the project, those exports must be added to this section and to the deletion procedure.

6. Logs

- `sync_logs` rows are user-scoped and removed during account deletion.
- `consents` rows are user-scoped and removed during account deletion. Until then, they are retained as audit (no automatic expiry).

- Vercel deployment / function logs are not user-scoped in the application's control; they age out per Vercel's retention.

7. Periodic review

This policy is reviewed annually (calendar reminder set for 2027-05-06). Each review confirms:

- The list of user-scoped collections in §2 / §4 / `deleteUser.js` is still complete.
- The deletion script still runs successfully against a test account in a non-production environment.
- The 7-day SLA from §4 is still being met for any actual deletion requests received in the prior 12 months.

8. References

- `PRIVACY_POLICY.md` §3, §7 — what is stored, how to request deletion
- `CONSENT.md` §5 — withdrawal of consent (per-institution disconnect)
- `backend/scripts/deleteUser.js` — the deletion script
- `backend/routes/plaid.js` → `DELETE /accounts/:itemId` — per-institution disconnect endpoint